

Daily Vulnerability Report - 2026-10-04

Window (UTC): 2026-10-03T07:15 to 2026-10-04T07:15 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-10-04 07:16:02 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
94	69	25	0	0	5	29	45	8	0

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105105	New	9.8	CRIT				CWE-306: Missing Authentication for Critical Function in the ait.core.server telemetry and command broker (ait-server) in NASA-AMMOS AIT-Core through 3.1.1 allows an unauthenticated remote attacker with network access to the ZeroMQ message bus to inject spacecraft command data, exfiltrate command and telemetry traffic, inject forged telemetry, or disrupt the command and tele...
CVE-2026-71885	New	9.2	CRIT		0.002		In Bouncy Castle for Java before 1.86, the Messaging Layer Security (MLS, RFC 9420) implementation did not bind an X.509 credential to a LeafNode's signature_key. LeafNode.verify() checked a leaf's signature against the signature_key carried in the leaf itself, while the credential's X.509 certificate chain was stored but never parsed or validated, so the end-entity certific...
CVE-2026-87115	New	9.1	CRIT		0.009		The VikAppointments Services Booking Calendar plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the extract function in all versions up to, and including, 1.2.21. This makes it possible for unauthenticated attackers to delete arbitrary files on the server, which can easily lead to remote code execution when the right fi...
CVE-2026-92084	New	9.1	CRIT		0.005		The The Beaver Builder Page Builder – Drag and Drop Website Builder plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 2.11.0.5. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for unauthenticated attackers to exec...
CVE-2026-105123	New	8.8	HIGH				W (vincent-peugnet/wcms) through 3.18.0 contains a remote code execution vulnerability that allows authenticated editors to write arbitrary files by abusing the unvalidated path in POST /api/v0/media/upload/[*:path]. Attackers can upload .php files executed by the web server, use encoded ../ sequences to write outside the media directory, and delete arbitrary files via DELET...
CVE-2026-18443	New	8.8	HIGH		0.004		The Smart Manager – Advanced WooCommerce Bulk Edit & Inventory Management plugin for WordPress is vulnerable to generic SQL Injection via the 'access_privileges' parameter in all versions up to, and including, 8.97.0 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticat...
CVE-2026-96451	New	8.8	HIGH				Authorization Bypass Through User-Controlled Key vulnerability in Ultimate Member Ultimate Member ultimate-member allows Privilege Escalation.This issue affects Ultimate Member: from n/a through 2.13.1.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71888	New	8.7	HIGH		0.001		In Bouncy Castle for Java before 1.86, the streaming CMS AuthenticatedData parser accepted a message whose digestAlgorithm and authAttrs fields disagreed about whether authenticated attributes were present. RFC 5652 sec. 9.1 pairs the two, requiring that authAttrs be present whenever digestAlgorithm is, and sec. 9.2 makes the MAC cover the DER encoding of authAttrs when they...
CVE-2026-71889	New	8.7	HIGH		0.002		In Bouncy Castle for Java before 1.86, neither copy of PKIXCertPathReviewer - org.bouncycastle.pkix.jcajce.PKIXCertPathReviewer nor the legacy org.bouncycastle.x509.PKIXCertPathReviewer - applied X.509 name constraints to the end-entity certificate. checkNameConstraints walked the path with a loop bound of index greater than zero, which is the bound the CA-only steps require...
CVE-2026-71890	New	8.7	HIGH		0.002		In Bouncy Castle for Java before 1.86, validation of an MLS (RFC 9420) external commit's proposal list, org.bouncycastle.mls.protocol.Group.validateExternalCachedProposals, counted the proposals by type and bounded the removed leaf index but never established that the removed leaf had anything to do with the joiner. RFC 9420 sec. 12.2 permits at most one Remove proposal in a...
CVE-2026-88779	New	8.7	HIGH				Vulnerability in NetScaler ADC and NetScaler Gateway. This issue affects ADC: before 14.1-73.41, before 13.1-64.28, before 14.1-73.41 FIPS, and before 13.1-37.282; Gateway: before 14.1-73.41 and before 13.1-64.28.
CVE-2026-105115	New	8.6	HIGH				OpenAM before 16.1.3 contains an unauthenticated arbitrary class instantiation vulnerability in the legacy JAX-RPC SOAP interface that allows remote attackers to load classes without authentication. Attackers can send SOAP requests to /jaxrpc/* with an unverified session identifier and a chosen class name, crashing the server, probing the classpath, or potentially reaching c...
CVE-2026-103065	New	8.2	HIGH				Improper Validation of Specified Quantity in Input vulnerability in Themeum Kirki kirki allows Accessing Functionality Not Properly Constrained by ACLs.This issue affects Kirki: from n/a through 6.3.1.
CVE-2026-71883	New	8.2	HIGH		0.003		In Bouncy Castle for Java LTS before 2.73.13, the one-shot native packet ciphers for AES-CBC, CCM, CFB, CTR, GCM and GCM-SIV released the caller's key, IV and additional authenticated data arrays with JNI's ReleaseByteArrayElements in mode 0, which commits the native copy back into the Java array. Those arrays are read-only to the native code, and on a JVM that returns a cop...
CVE-2026-71886	New	8.2	HIGH		0.002		In Bouncy Castle for Java before 1.86, the high-level OpenPGP certificate API accepted a third-party certification or trust delegation from any component key of the issuing certificate, without requiring that component to have been granted the authority to certify. OpenPGPCertificate.getCertificationBy() and getDelegationBy() resolve a third-party signature by matching its i...
CVE-2026-71887	New	8.2	HIGH		0.001		In Bouncy Castle for Java before 1.86, the high-level OpenPGP API accepted a data signature made by a signing subkey whose Subkey Binding signature carried no embedded Primary Key Binding (cross-certification) signature, in the case where that binding omits a Key Flags subpacket. RFC 9580 sec. 5.2.1.8 and sec. 10.1.3 require the embedded Primary Key Binding signature on any ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85515	New	8.2	HIGH		0.002		In Bouncy Castle for Java before 1.86, a truncated OpenPGP encrypted message was accepted with no error reported, and on the SEIPD version 1 path with no integrity check performed at all. RFC 9580 sec. 13.7 permits an implementation to release the cleartext of the fully authenticated chunks when streaming but requires it to indicate a clear error as soon as the truncation is...
CVE-2026-94505	New	8.1	HIGH		0.003		The Nelio Content – Editorial Calendar & Social Media Auto-Posting plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 4.5.0 This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with contributor-level access and above, to permanently de...
CVE-2026-75028	New	7.5	HIGH		0.007		The WPCafe – Restaurant Menu, Online Food Ordering & Table Booking System plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 3.0.18 via the (template scope) function. This makes it possible for authenticated attackers, with contributor-level access and above, to include and execute arbitrary .php files on the server, allowing the...
CVE-2026-96267	New	7.5	HIGH		0.003		The WP Visitor Statistics (Real Time Traffic) plugin for WordPress is vulnerable to generic SQL Injection via the 'fullRef' parameter in all versions up to, and including, 8.7 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for unauthenticated attackers to append additional SQL q...
CVE-2026-105126	New	7.2	HIGH				LaraDashboard before 1.4.8 contains an improper privilege management vulnerability that allows authenticated Admin users to escalate to Superadmin by editing or renaming roles. Attackers with role.edit can rename their role to Superadmin or grant user.login_as permissions to take over accounts and reach core upgrade and module installation functions for code execution.
CVE-2026-93889	New	7.2	HIGH		0.002		The Mail logging – WP Mail Catcher plugin for WordPress is vulnerable to Stored Cross-Site Scripting via PHPMailer 'wp_mail_failed' Error Message in all versions up to, and including, 2.1.12 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a use...
CVE-2026-97660	New	7.2	HIGH		0.003		The WPC Product Options for WooCommerce plugin for WordPress is vulnerable to Stored Cross-Site Scripting via wpcpo-* Array Key via Multipart Field Name in all versions up to, and including, 4.0.5 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever...
CVE-2026-103342	New	7.1	HIGH				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Unlimited Elements Unlimited Elements For Elementor (Free Widgets, Addons, Templates) unlimited-elements-for-elementor allows Reflected XSS.This issue affects Unlimited Elements For Elementor (Free Widgets, Addons, Templates): from n/a through 2.0.20.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71891	New	7.1	HIGH		0.002		In Bouncy Castle for Java before 1.86, BLS12_381BasicScheme.keyValidate, and so BLSPublicKeyParameters and every BasicScheme, MessageAugmentation and ProofOfPossession verify and aggregateVerify that gate on it, accepted a public key built on a foreign ECCurve that merely shares BLS12-381's field characteristic. The prime-order subgroup check trusts a point's own curve to na...
CVE-2026-71892	New	6.9	MEDI		0.002		In Bouncy Castle for Java before 1.86, the opt-in key-size validation on CMS key-transport recipients, org.bouncycastle.cms.jcajce.JceKeyTransRecipient.setKeySizeValidation(true), never ran for a message using RFC 9709 content-encryption key derivation (id-alg-cek-hkdf-sha256). The branch that should have selected the actual content-encryption algorithm carried in the key de...
CVE-2026-105119	New	6.8	MEDI				OpenAM before 16.1.3 applies its OAuth2 Provider PKCE enforcement only to authorization requests whose response_type is exactly code, so codes issued through OpenID Connect hybrid flows (code token, code id_token, code token id_token) carry no bound challenge. An attacker who intercepts such a code can redeem it for a public client's tokens with any non-empty code_verifier.
CVE-2026-100157	New	6.5	MEDI		0.003		The The WP Ultimate Review plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 2.4.3. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for unauthenticated attackers to execute arbitrary shortcodes. The nonce required...
CVE-2026-105113	New	6.5	MEDI				Nezha Dashboard from 1.8.0 before 2.3.13 contains an improper locking vulnerability where a non-deferred mutex unlock leaks on a nil-map panic path. Any authenticated non-admin member can issue four notification API calls to permanently deadlock the alerting subsystem, then exhaust memory with blocking requests.
CVE-2026-105129	New	6.5	MEDI				LaraDashboard before 1.4.8 contains an incorrect authorization vulnerability that allows authenticated users with only settings.view permission to read stored secrets through the settings API. Attackers can query GET /api/settings or /api/settings/{option_name} to retrieve plaintext AI provider API keys, mail credentials, passwords and tokens.
CVE-2026-15795	New	6.4	MEDI		0.002		The Responsive Plus – Elementor Templates & Starter Sites plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Shortcode Attributes in all versions up to, and including, 3.5.3 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web scripts...
CVE-2026-92767	New	6.4	MEDI		0.002		The Twenty20 Image Before-After plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'offset' Shortcode Attribute in all versions up to, and including, 2.0.5 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web scripts in pages that wil...
CVE-2026-104983	New	6.3	MEDI				A vulnerability has been found in Linux Mint Xreader up to 4.6.9. Impacted is the function g_file_get_child of the file shell/ev-window.c of the component PDF Attachment Saving Handler. Such manipulation of the argument attachment leads to path traversal. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. One of the project...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105096	New	6.3	MEDI				A vulnerability was determined in Omega Solution CoinEx Crypto 2025. This affects an unknown function of the file /customer/ of the component Customer Profile API. Executing a manipulation of the argument ID can lead to authorization bypass. The attack may be launched remotely. The exploit has been publicly disclosed and may be utilized. The product web site does not exist a...
CVE-2026-104313	New	6.1	MEDI		0.002		The WPC Estimated Delivery Date for WooCommerce plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'rule_data' parameter in all versions up to, and including, 4.0.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they can success...
CVE-2026-105114	New	6.1	MEDI				OpenAM before 16.1.3 contains a reflected cross-site scripting vulnerability that allows unauthenticated attackers to inject script by supplying crafted parameters rendered unencoded on the OAuth2 authorization error page. Attackers can lure victims to a crafted /oauth2/authorize link with repeated parameters to run JavaScript in the OpenAM origin, acting within existing ses...
CVE-2026-105116	New	6.1	MEDI				OpenAM before 16.1.3 contains a latent cross-site scripting defect that places the SAML message, relay state and target URL unencoded into the load-balancer cookie bounce auto-submit page. If reachable with cookieHashRedirectEnabled set, crafted requests could execute script in the OpenAM origin, though an unrelated HTTP 500 failure prevents exploitation in released versions.
CVE-2026-105117	New	6.1	MEDI				OpenAM before 16.1.3 contains an email content injection vulnerability that allows unauthenticated attackers to control notification email wording via the forgotPassword and register actions on /json/{realm}/users. Attackers can supply subject and message fields to send phishing mail from the organisation's configured From address, or abuse register as a relay to arbitrary r...
CVE-2026-105124	New	6.1	MEDI				W (vincent-peugnet/wcms) through 3.18.0 contains a stored cross-site scripting vulnerability that allows unauthenticated attackers to inject scripts via the login user field and visitor comment website field. Attackers can submit failed logins rendered unescaped in the adminlog.php log viewer, or comment URLs echoed into href attributes in editrightbar.php, executing script ...
CVE-2026-92974	New	6.1	MEDI		0.002		The Photo Gallery by 10Web – Mobile-Friendly Image Gallery plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'thumb_url' parameter in all versions up to, and including, 1.8.46 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they...
CVE-2026-93896	New	6.1	MEDI		0.002		The WPFront Notification Bar plugin for WordPress is vulnerable to Reflected Cross-Site Scripting in versions up to, and including, 3.5.1. This is due to the debug-log output path (write_debug_logs) reflecting the raw value of \$_SERVER['REQUEST_URI'] through vprintf() directly inside a <script> block emitted on wp_footer, without any sanitization or escaping (see the 'Curren...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18040	New	5.9	MEDI		0.001		In Bouncy Castle for Java before 1.86, HQC leaked secret-derived data through two side channels: its GF(2^8) arithmetic used lookup tables indexed by field elements, making the cache line touched a function of the operand, and its fixed-weight support sampler left its duplicate scan as soon as a collision was found and stored accepted positions at a secret index. Both run on...
CVE-2026-103421	New	5.4	MEDI		0.002		The WPMobile.App – Android and iOS App Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'REQUEST_URI (path segment after /android_json/search/)' parameter in all versions up to, and including, 11.84 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts ...
CVE-2026-103519	New	5.4	MEDI		0.003		The The WP Ultimate Review plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 2.4.3. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for authenticated attackers, with subscriber-level access and above, to execute a...
CVE-2026-105122	New	5.4	MEDI				OpenAM before 16.1.3 contains a server-side request forgery vulnerability that allows attackers able to register or modify OAuth 2.0 clients to make OpenAM fetch internal resources via an unvalidated jwks_uri. Attackers can trigger unauthenticated fetches through client-authentication and ID-token validation to probe internal hosts, metadata endpoints or local files, or exha...
CVE-2026-105128	New	5.4	MEDI				LaraDashboard before 1.4.8 contains an open redirect vulnerability that allows remote attackers to redirect users by supplying an unvalidated redirect_url parameter to EmailTemplateController builder and builderEdit. Attackers can send crafted builder links to logged-in users with email template permissions so saving a template navigates them to attacker-controlled phishing ...
CVE-2026-105131	New	5.4	MEDI				ezBookkeeping 1.2.0 before 2.0.1 contains a privilege escalation vulnerability that allows attackers holding an API token to obtain a full session token via /api/v1/tokens/refresh.json. Because TokenRefreshHandler never checks token type, attackers can exchange short-lived or IP-restricted API tokens for 30-day normal session tokens that bypass API token expiry and allowlists.
CVE-2026-105112	New	5.3	MEDI				Nezha from 1.8.0 before 2.3.13 contains a lock-order inversion in UpdateGroup and DeleteGroup that allows authenticated non-admin users to deadlock the alerting subsystem. Attackers can concurrently call the notification-group and batch-delete endpoints with oversized id lists to widen the race and close an ABBA cycle, permanently killing alert delivery until restart.
CVE-2026-105127	New	5.3	MEDI				LaraDashboard 1.4.2 before 1.4.8 applies advanced email validation to unauthenticated forgot-password and reset-password requests, triggering DNS lookups and paid AbstractAPI verification calls. Unauthenticated attackers can submit arbitrary addresses to exhaust the verification quota, making validation fail open for all public forms, and probe domain resolution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-11601	New	5.3	MEDI		0.004		The WPCafe – Restaurant Menu, Online Food Ordering & Table Booking System plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 3.0.19. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to read, create, update, clone, and delete email...
CVE-2026-97873	New	5.3	MEDI		0.003		In Bouncy Castle for Java before 1.86, the raw JCA provider's legacy PBES1 (PKCS#5 scheme 1) and PKCS#12 PBE families ran their password-based key derivation with an iteration count taken from untrusted input without bounding it, so a small input could dictate an arbitrary amount of work before anything could be verified. The AlgorithmParameters implementations (PKCS12PBE an...
CVE-2026-105120	New	4.9	MEDI				OpenAM before 16.1.3 contains an authorization bypass vulnerability in the sessions REST endpoint query operation that allows realm administrators to list sessions of every realm. Attackers holding delegated RealmAdmin privileges can supply a _queryFilter naming another realm to disclose usernames, universal IDs, and session handles across tenant boundaries.
CVE-2026-105121	New	4.9	MEDI				OpenAM before 16.1.3 contains an improper authorization vulnerability that allows delegated administrators to destroy sessions outside their realms because realm checks use the requester's realm. Authenticated accounts holding the iplanet-am-session-destroy-sessions attribute can supply a target session identifier or handle to forcibly log out users in any realm.
CVE-2026-105118	New	4.7	MEDI				OpenAM before 16.1.3 contains an open redirect vulnerability that allows unauthenticated attackers to redirect users by supplying an unverified id_token_hint to the /oauth2/connect/endTime endpoint. Attackers can name any realm client in a forged hint to redirect victims to any registered post-logout URI, enabling phishing that borrows the OpenAM host's trust.
CVE-2026-104982	New	4.3	MEDI		0.004		A flaw has been found in Linux Mint Xreader up to 4.6.5. This issue affects the function setup_document_content_list/g_strdup_printf of the file backend/epub/epub-document.c of the component EPUB File Handler. This manipulation causes path traversal. The attack is possible to be carried out remotely. The exploit has been published and may be used. Upgrading to version 4.6.6 ...
CVE-2026-105097	New	4.3	MEDI				A vulnerability was identified in Omega Solution CoinEx Crypto 2025. This impacts an unknown function of the file /customer-currency/ of the component Customer Information API. The manipulation of the argument ID leads to authorization bypass. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The product web site does not exi...
CVE-2026-105098	New	4.3	MEDI				A security flaw has been discovered in Omega Solution CoinEx Crypto 2025. Affected is an unknown function of the file /ticket/customer of the component Support Ticket API. The manipulation of the argument status/page/count results in information disclosure. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The produ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97343	New	4.3	MEDI		0.003		The Burst Statistics – Simple WordPress Analytics (Google Analytics Alternative) plugin for WordPress is vulnerable to Improper Authentication leading to Account Persistence in all versions up to, and including, 3.7.1. This is due to the <code>`maybe_load_shared_dashboard()`</code> handler issuing a genuine WordPress session cookie for the <code>`burst_statistics_viewer`</code> account to any visitor...
CVE-2026-105125	New	3.7	LOW				LaraDashboard before 1.4.8 contains a path traversal vulnerability that allows unauthenticated attackers to read JSON files by manipulating the {lang} route segment. On Windows hosts, attackers can send URL-encoded backslash sequences like <code>..%5C</code> to escape resources/lang and read composer.json or other application JSON files.
CVE-2026-105130	New	3.7	LOW				LaraDashboard from 1.4.0 before 1.4.8 contains a race condition vulnerability in RegisterController::register that allows unauthenticated attackers to bypass the per-IP daily registration limit. Attackers can send many concurrent registration requests from one IP so all pass RegistrationGuardService::hasExceededIpLimit before recordRegistration runs, creating accounts in bul...
CVE-2026-105099	New	3.5	LOW				A weakness has been identified in Omega Solution CoinEx Crypto 2025. Affected by this vulnerability is an unknown functionality of the file /user/ticket of the component Ticket Attachment Upload. This manipulation causes cross site scripting. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used for attacks. Th...
MAL-2026-17464	New					PyPI:voxcpmui3	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (5050cd1cac91a217e828de6f54792051b810c43bf9ee5d53e913479fb059715c) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17465	New					PyPI:voxcpmeval	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (18746c0b1bc840ee608e3aba81f9e18e4411373b8993d315177e95614fe67b08) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17466	New					PyPI:voxcpmkit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (92a0735c100233f803adcf4cec20645acbb5f01b1757e8889dfaa631e49dae71) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17467	New					PyPI:voxcpmui4	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (c0f6ddfc6a324d42219bbea8405be17115f83eca0e2d2eeeb4e3fe6b6ec3dbde) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17468	New					PyPI:voxcpmintel	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (28ef552864bd4b4558137163734077a2429281647a26868f40d8d735af95c967) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17469	New					PyPI:infrabench	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (4abc7154004498e9054ca8ac239acd73ab86815f6029ad5d52e4c883488f4c70) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17470	New					PyPI:voxcpmruntime	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (12f18950a276ca27a304d3053835b0102656168083e7ddf414fffb112cbe01ba) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17471	New					PyPI:caoxilts	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (c0d27d780e356c6ae75dedaa144f2064476e275a02f801a1d56897a3a9d1930f) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103626	Updated - CVSS added	9.6	CRIT		0.002		Incorrect authorization in FileSystem in Google Chrome on on Windows prior to 154.0.8037.97 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-88783	Updated - CVSS added	8.8	HIGH		0.002		The Kubio AI Page Builder WordPress plugin before 2.9.3 does not limit its widening of the allowed HTML elements to the editor context, so the wider set is applied when filtering content submitted by unauthenticated users as well, allowing them to store markup which the Kubio AI Page Builder WordPress plugin before 2.9.3's own script later executes in the browser of any visi...
CVE-2026-89236	Updated - CVSS added	8.6	HIGH		0.002		The SaveTo Wishlist Lite WordPress plugin before 1.1.5 does not sanitise and escape parameters before using them in the ORDER BY clause of a SQL query, allowing unauthenticated attackers to append additional SQL queries and extract sensitive information from the database.
CVE-2026-103624	Updated - CVSS added	8.3	HIGH		0.002		Use after free in Contextual Tasks in Google Chrome on on Windows prior to 154.0.8037.97 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-91078	Updated - CVSS added	8.2	HIGH		0.001		The TillKit WordPress plugin before 1.0.5 does not require the hard-coded, publicly known PIN of the privileged POS account it creates on activation to be changed before use, and it authenticates its public POS login endpoint on that PIN alone with no identity or capability check, allowing unauthenticated attackers to obtain a privileged POS session and thereby read customer...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101159	Updated - CVSS added	7.5	HIGH		0.002		The WP Ultimate Review WordPress plugin before 2.4.4 does not properly sanitise and escape reviews submitted through its public review form, which is available to unauthenticated visitors, allowing them to perform Stored Cross-Site Scripting attacks against any user, including administrators, viewing a page displaying the review, when user reviews are enabled.
CVE-2026-101160	Updated - CVSS added	7.5	HIGH		0.002		The WP Ultimate Review WordPress plugin before 2.4.4 does not validate that a submitted review rating is numeric before storing it and later using it in numeric operations when rendering reviews, allowing unauthenticated users to make the reviewed content fail with a fatal error for all visitors until the review is removed (a persistent denial of service), when user reviews ...
CVE-2026-101161	Updated - CVSS added	7.5	HIGH		0.002		The WP Ultimate Review WordPress plugin before 2.4.4 does not prevent unauthenticated users from storing crafted review content that makes the reviewed page fail with a fatal error on every subsequent visit, resulting in a persistent denial of service when the WP Ultimate Review WordPress plugin before 2.4.4's review display settings have never been saved.
CVE-2026-103514	Updated - CVSS added	7.5	HIGH		0.002		The WP 2FA WordPress plugin before 4.1.0 does not invalidate a time-based one-time passcode once it has been used, allowing an attacker who knows an account's password and has observed a valid code within its validity window to replay it and bypass two-factor authentication, including on administrator accounts.
CVE-2026-103293	Updated - CVSS added	6.8	MEDI		0.002		The MPG WordPress plugin before 4.2.3 does not validate that the dataset source supplied when importing a project is a remote URL before treating it as a local filesystem path and copying that file into a publicly accessible uploads folder. This makes it possible for users with the Editor role and above to read the contents of arbitrary files on the server, with the copied ...
CVE-2026-85568	Updated - CVSS added	6.8	MEDI		0.002		The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not correctly handle a search value before rewriting an already prepared SQL statement, allowing unauthenticated users to perform SQL injection attacks and to retrieve non-public content, when a related widget option is set away from its default.
CVE-2026-88782	Updated - CVSS added	6.8	MEDI		0.002		The Kubio AI Page Builder WordPress plugin before 2.9.3 does not validate the URI scheme of a user-supplied value before outputting it as a link target, allowing users with the contributor role and above to store a payload which executes in the browser of anyone who follows the link, including an administrator previewing the unpublished submission.
CVE-2026-94238	Updated - CVSS added	6.8	MEDI		0.002		The Loco Translate WordPress plugin before 2.8.9 does not restrict which file paths its translation file routes will read, allowing users granted the Loco Translate WordPress plugin before 2.8.9's translator capability to retrieve the contents of files of certain types from anywhere on the server, including outside the web root.
CVE-2026-94239	Updated - CVSS added	6.8	MEDI		0.002		The Loco Translate WordPress plugin before 2.8.9 does not sanitise and escape some bundle configuration values before outputting them back in an admin page, allowing users with the translator capability and above to perform Stored Cross-Site Scripting attacks against high privilege users such as administrators.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85015	Updated - CVSS added	6.6	MEDI		0.002		The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not sanitise file paths inside uploaded archives before extracting them, allowing authenticated users with access to its asset-management feature (Administrators by default, or Editors when a non-default Unlimited Elements for Elementor WordPress plugin before 2.0.21 setting is enabled) to write arbitra...
CVE-2026-101162	Updated - CVSS added	6.4	MEDI		0.002		The WP Ultimate Review WordPress plugin before 2.4.4 does not escape some of its review overview settings before outputting them in posts, which could allow users with a role as low as author to perform Stored Cross-Site Scripting attacks, when author reviews are enabled.
CVE-2026-92923	Updated - CVSS added	6.3	MEDI		0.002		The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not sanitise and escape a parameter before using it in a SQL statement, allowing users with a role as low as subscriber to perform blind SQL injection attacks and read arbitrary data from the database. Version 2.0.18 removed the subscriber-level access, so from 2.0.18 onward the issue requires a Contrib...
CVE-2026-86832	Updated - CVSS added	5.3	MEDI		0.001		The MetForm WordPress plugin before 4.3.1 does not properly restrict access to form submission data, allowing unauthenticated attackers to view submitter information through the REST API.
CVE-2026-92437	Updated - CVSS added	5.3	MEDI		0.002		The Mailchimp for WooCommerce WordPress plugin before 6.3 does not require authentication, a nonce or an ownership check before it acts on a customer's abandoned-cart record identified from request-supplied data, allowing an unauthenticated attacker to modify or delete another customer's stored cart.
CVE-2026-103621	Updated - CVSS added	4.3	MEDI		0.002		Integer overflow in Compositing in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to leak cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103629	Updated - CVSS added	4.3	MEDI		0.002		Integer overflow in Skia in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to leak cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-80518	Updated - CVSS added	3.7	LOW		0.001		The WP Ultimate CSV Importer WordPress plugin before 9.2 does not use a site-specific secret when deriving the storage location of the import logs it writes under the uploads directory, nor does it block direct access to them, allowing unauthenticated attackers to retrieve the personal data of users imported from a CSV file.
CVE-2026-86834	Updated - CVSS added	3.7	LOW		0.001		The MetForm WordPress plugin before 4.3.1 does not properly restrict access to a debug file it writes to the web root on every form submission when its HubSpot Forms integration is enabled, allowing unauthenticated attackers to read upstream API response data, including correlation identifiers and cookies.
CVE-2026-96962	Updated - CVSS added	3.7	LOW		0.001		The Pie Register WordPress plugin before 3.8.4.14 does not restrict access to an invitation-code report, allowing unauthenticated visitors who know a valid invitation code to obtain the username and email address of every user who registered with that code.
CVE-2026-80517	Updated - CVSS added	3.5	LOW		0.002		The WP Ultimate CSV Importer WordPress plugin before 9.2 does not properly validate the file types contained in an uploaded archive nor sanitise their content before storing them in a publicly served location, allowing high privilege users such as administrators to achieve Stored Cross-Site Scripting. On Multisite installations a site Administrator does not hold the unfile...

Added to CISA KEV today

None in this window.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-105105	New	9.8	CRIT				CWE-306: Missing Authentication for Critical Function in the ait.core.server telemetry and command broker (ait-server) in NASA-AMMOS AIT-Core through 3.1.1 allows an unauthenticated remote attacker with network access to the ZeroMQ message bus to inject spacecraft command data, exfiltrate command and telemetry traffic, inject forged telemetry, or disrupt the command and tele...
CVE-2026-71885	New	9.2	CRIT		0.002		In Bouncy Castle for Java before 1.86, the Messaging Layer Security (MLS, RFC 9420) implementation did not bind an X.509 credential to a LeafNode's signature_key. LeafNode.verify() checked a leaf's signature against the signature_key carried in the leaf itself, while the credential's X.509 certificate chain was stored but never parsed or validated, so the end-entity certific...
CVE-2026-87115	New	9.1	CRIT		0.009		The VikAppointments Services Booking Calendar plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the extract function in all versions up to, and including, 1.2.21. This makes it possible for unauthenticated attackers to delete arbitrary files on the server, which can easily lead to remote code execution when the right fi...
CVE-2026-92084	New	9.1	CRIT		0.005		The The Beaver Builder Page Builder – Drag and Drop Website Builder plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 2.11.0.5. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for unauthenticated attackers to exec...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.